CloudDesk Technologies

Change Management Policy

1. Authority, scope and responsibilities

SYNTHETIC / DEMO - document control

CD-CHG-001 | Version 1.0 | Fictional effective date: 2026-10-22 | Next review: 2027-10-22. Owner and process coordinator: Engineering Lead. Accountable risk approver: CTO; approval not recorded. Review annually and after material changes, significant incidents or failed changes. Editable JSON is the source of truth for this PDF.

Status and adoption limits

CloudDesk Technologies is a fictional 75-person B2B SaaS vendor. This model-authored Policy 6 of an intended eight-policy collection contains proposed SYNTHETIC / DEMO requirements, not operating facts. Review_status: requires_user_review. No implemented controls, completed deployments, existing staff coverage, approvals, SLA, deployment frequency, certification, SOC 2 report or compliance conclusion is asserted. Human review and recorded approval are required before adoption.

Scoped changes and related authority

Cover production application code, database schemas and data migrations, infrastructure and infrastructure as code (IaC), cloud configuration, security controls, identity permissions, encryption keys, backup methods, recovery runbooks and vendor integrations. Include manual console changes, feature flags, scripts and vendor-driven changes affecting production. Development changes with a production impact follow this process. The five related policies remain authoritative for access, encryption, risk, incident authority and backup/disaster recovery; record conflicts for Engineering Lead and CTO resolution before adoption.

Responsibilities and independent review

System owners and change requesters document impact, dependencies, tests, deployment, monitoring and rollback. Engineering Lead coordinates classification, scheduling, approvals and records; CTO accepts material residual risk and authorizes exceptions. Assign an independent competent reviewer where feasible and separate requester, reviewer and deployment approval duties. No staffed change board or dedicated release team is assumed. If limited capacity prevents separation, record the conflict and obtain CTO approval of compensating review before a planned deployment; do not silently self-approve.

Change Management Policy

2. Classification, requests and authorization

Standard changes - bounded preauthorization

A standard change is repeatable and low risk only within a documented, tested procedure preauthorized by Engineering Lead, with CTO acceptance of any material residual risk. A proposed standard-change catalogue must define eligibility, exact scope, version, validation, rollback, authorized operators and review/expiry conditions. Each execution still needs a ticket, eligibility check and recorded preauthorization before deployment. No catalogue is supplied or approved here. Deviation, failed validation or changed risk removes eligibility and requires normal or emergency handling.

Normal changes and approval gates

A normal change is any planned scoped change that lacks valid standard preauthorization. Before deployment require peer review, system-owner acceptance of service impact and Engineering Lead process approval; CTO approves material residual risk, major service impact and exceptions. Record named decision makers, decision time, scope and conditions. Reassess and reapprove if scope, artifact, risk or timing materially changes. A merged pull request is not by itself proof of deployment authorization or successful release.

Ticketed change request

Use a unique change ID and record requester, owner, classification rationale, affected services/assets, tenant scope, dependency map, exact artifact/configuration versions and linked pull requests. Assess business impact, security, privacy, cross-tenant risks, data migration reversibility, availability and vendor obligations. Include test evidence and limitations, deployment steps, proposed timing and time zone, communications, verification/stop criteria, rollback or forward-recovery plan, decision authority and linked risks/incidents. Do not put secrets or unnecessary customer data in tickets.

Emergency classification and risk assessment

Emergency changes address active harm or urgent exposure where the normal path would increase risk; convenience or missed planning is insufficient. Link an incident and record urgency, alternatives, expected harm, minimum safe testing and recovery dependencies. Assess risks before material service changes and vendor onboarding under CD-ISP-001, retaining its at least annual risk assessment and quarterly open-risk reviews. CTO accepts material residual risk. Emergency authority and retrospective review are detailed on page 5; do not wait for routine approvals to stop active harm.

Change Management Policy

3. Engineering safeguards and testing

Version control, peer review and CI

Store production code, infrastructure definitions and reviewable configuration in version-controlled pull requests. Link the change ticket to the exact reviewed commit and immutable release artifact identifier or digest. Review security/privacy impact and CI/tests appropriate to the change, including unit, integration and migration checks. Record failures and their resolution; block planned release on unresolved required checks unless an approved, bounded exception applies. Protect production branches and deployment permissions as proposed safeguards; no existing repository protection or pipeline is claimed.

Secrets, access and encryption safety

Review diffs and CI output for secrets; use the approved secrets manager, restricted service identities and redacted logs. Do not copy credentials, private keys or production data into repositories or build artifacts. Preserve unique user accounts, multi-factor authentication for administrative access, access reviews every quarter and termination revocation within 24 hours. Scoped changes must preserve AES-256 at rest, TLS 1.2 or TLS 1.3 in transit, managed non-exportable KMS keys and no default decrypt permission for key administrators. Engineering Lead approves key grants; review grants quarterly.

Tenant isolation and migration tests

Test positive authorized tenant workflows and negative cross-tenant access attempts, including object identifiers, API authorization, exports, background jobs, caches and privilege changes where affected. Use synthetic data or authorized minimized test data in isolated environments. Exercise schema compatibility, old/new application coexistence, duplicate event handling and rollback of partially applied migrations. Failed tenant isolation, authorization or integrity checks block planned release; preserve results and remediate. A passing test suite is not proof that every tenant path is secure.

Restore, key dependencies and disaster recovery

For changes affecting storage, keys, identity, backups or recovery, test a representative encrypted restore and authorized key access as appropriate before planned rollout; document integrity, recovery outcome and dependency limitations. Preserve backup-specific key grants and required older key versions for retained data/backups and holds. Rotate symmetric key-encryption keys at least every 12 months; rotation alone does not re-encrypt historical data. Destruction requires Engineering Lead and CTO approval after retention and recovery checks. Change testing supplements representative encrypted restore tests at least quarterly and continuity exercises at least annually and after material changes; neither substitutes for the other.

Change Management Policy

4. Scheduling, deployment and verification

Timing, coordination and change freeze

Engineering Lead coordinates a proposed change calendar, dependent releases, vendor windows, customer impact and available authorized support. Choose timing using risk and contractual commitments; no fixed deployment cadence, maintenance window or staffed coverage is assumed. Record a change freeze for sensitive business periods, unstable service or incidents, with scope, owner and end conditions. Defer planned scoped changes during a freeze; CTO approves documented risk-based exceptions. Urgent containment follows incident authority even during a freeze.

Staged rollout and controlled execution

Before deployment verify approvals or valid standard preauthorization, reviewed artifact identity, required tests, recovery readiness, trusted access and communication plan. Deploy through authorized identities and a recorded runbook. Where feasible use staging, canary cohorts or feature flags, then expand only after defined health and tenant checks. Record manual console actions and reconcile them into reviewed configuration/IaC. Pause when monitoring or responsible authorized coverage is unavailable; assess an emergency separately. Do not treat staging success as proof of production safety.

Post-deployment verification and monitoring

Compare actual production state to the approved version; check application health, error rates, latency, security signals, tenant boundaries, data integrity and affected user workflows against ticketed acceptance criteria. Set a risk-based observation period and escalation contacts per change without inventing a universal time limit. Record who verified, when, observed results, gaps and decision to expand, hold or stop. System owner records acceptance; Engineering Lead checks closure evidence. CTO approves material residual risk and critical-service return under incident authority when applicable.

Failed changes, rollback and forward recovery

Stop rollout on failed acceptance criteria, suspected tenant exposure, integrity loss or renewed incident indicators. Use the validated rollback plan only if safe; irreversible migrations require a reviewed forward-recovery or restore plan and decision authority before planned deployment. Preserve evidence, record actual state and isolate unsafe paths rather than blindly restoring an old version. Link or open an incident for suspected exposure or material disruption. Engineering Lead coordinates recovery, verifies containment and escalates material risk to CTO; retest before redeployment.

Change Management Policy

5. Emergency changes and policy boundaries

Immediate containment authority

Under CD-IRP-001 responders may take urgent reversible action to stop active harm, documenting scope and informing Engineering Lead and CTO. Do not delay immediate containment solely for a ticket, routine approval or evidence collection; create or complete the linked incident/change record as soon as safe. CTO authorizes material service shutdowns and residual-risk decisions; seek verified alternate approval if unavailable and record unavoidable emergency decisions for review. This process does not expand authority for destructive actions, emergency decrypt access or external communications.

Emergency safeguards and next business day review

Use the smallest safe change, trusted identities, rapid peer input where feasible, minimum relevant testing, monitoring and a rollback/recovery path. Record any omitted checks and why, actions and artifact versions, actor, time, affected tenants, authorization basis and known uncertainty. Engineering Lead coordinates retrospective documentation; CTO reviews emergency changes by the next business day. Review necessity, scope, decisions, results and remaining risk; assign corrective actions and reconcile hotfixes into version control. Retrospective review does not convert unauthorized action into prior approval.

Key, backup and recovery constraints

Suspected key compromise requires an incident, revocation of affected grants and disabling compromised versions where safe; never blindly destroy keys needed for recovery. CTO authorizes temporary emergency decrypt access with logging and next-business-day review. Preserve CD-ENC-001 destruction approvals and CD-BDR-001 clean recovery, tenant integrity and dependency gates. Backup frequency, retention, RTO and RPO remain TBD pending BIA/business and contractual review; this change policy sets no numerical recovery objective or universal backup retention.

Vendor and privacy changes

Assess new or changed integrations, OAuth scopes, data flows, subprocessors, regions, exports and deletion behavior before enabling access to scoped information. Engineering Lead reviews vendor assessment and CTO accepts material residual risk; reassess critical vendors annually and after material changes or incidents. Record shared dependencies and exit/recovery limitations. Coordinate external communications through CTO with appropriate advice under CD-IRP-001; no universal notification deadline or provider assurance establishes CloudDesk compliance.

Change Management Policy

6. Records, exceptions and review

Proposed audit trail and retention

Expected records include ticket and classification, risk assessment, reviewed PR/commit and artifact identity, CI/test outputs, approval decisions and timestamps, deployment actor/actions, production verification, rollback, incident linkage and closure. Restrict evidence access, preserve version history, minimize personal data and record approved retention and holds before disposal. These are proposed records, not actual audit artifacts. Preserve minimum 12-month retention for KMS audit logs only; it is not a universal change-ticket, incident-evidence or backup retention rule.

Exceptions expire and require review

Before a planned deviation the owner records the requirement, scope, reason, security/privacy/tenant risk, compensating safeguards, remediation owner and expiry. Engineering Lead assesses and CTO approves or rejects. Exceptions expire within 90 days and are reviewed monthly; renewal requires fresh assessment and approval. Expired approval cannot authorize a planned deployment. Emergency deviations require a linked incident and CTO review by the next business day. Domain-specific access, encryption and destructive key authority remains in force. No active exception is asserted.

Periodic process and failed-change review

Engineering Lead reviews change records and the proposed standard catalogue at least quarterly and after significant failed changes or incidents. Check unauthorized changes, repeated emergencies, stale preauthorizations, approval conflicts, rollback outcomes and overdue corrective actions. Suspend unsafe standard procedures, assign remediation and retest before reuse. Feed material risks to the risk register, retain quarterly open-risk reviews and CTO risk acceptance, and assess security risk at least annually and before material changes. These proposed review activities are not claimed completed.

Annual policy review and human adoption gate

Engineering Lead reviews this policy annually and after material changes, significant incidents or lessons learned, and submits revisions to CTO. Human reviewers must validate staffing/substitutes, approval thresholds, feasible separation, actual CI and deployment controls, tenant tests, freeze rules, vendor dependencies and recovery readiness against all five related policies. Record reviewer feedback and CTO approval before operational adoption. Approval_status: not_recorded; review_status: requires_user_review. Successful PDF extraction, retrieval or software tests do not establish implemented controls, human semantic validation or compliance.